

가. 패스워드 일치 여부 확인 및 오류 횟수 제한

검증 방식

- **암호화 시:** 사용자가 입력한 패스워드를 SHA-512 해시 함수로 처리하여 해시값(digest)을 생성합니다. 이 해시값은 암호문, 솔트(salt), IV(Initialization Vector)와 함께 파일에 저장됩니다.
- **복호화 시:** 사용자에게 다시 패스워드를 입력받아 동일한 SHA-512 해시 함수로 해시값을 계산합니다. 이 계산된 해시값과 파일에 저장되어 있던 원본 해시값을 비교하여 패스워드의 일치 여부를 판단합니다.
- **보안성:** 이 방식은 패스워드 원문을 저장하지 않고, 단방향 암호화된 해시값을 비교하므로 만에 하나 파일이 탈취되더라도 패스워드가 직접 노출될 위험을 방지하는 안전한 방법입니다.

오류 횟수 파악

- 복호화를 시도할 때마다 attempt_count 변수를 1씩 증가시켜 사용자의 시도 횟수를 기록합니다.
- 패스워드가 틀렸을 경우, "비밀번호가 틀렸습니다. (시도 X)"와 같은 메시지를 출력하여 사용자에게 현재까지의 실패 횟수를 명확히 알려줍니다.
- 이를 통해 무차별 대입 공격(Brute-force attack) 시도를 인지하고 추적할 수 있습니다.

관련 코드

- storeUSB (82-95행): 암호화 시 패스워드 해시를 생성하고 파일에 저장합니다.
- verifyPassword (112-117행): 복호화 시 패스워드 해시를 비교하여 일치 여부를 검증합니다.
- PBE_Decryption (119-134행): 복호화 루프 내에서 시도 횟수를 계산하고, 검증 결과에 따라 적절한 메시지를 출력합니다.

나. 시간 동기화(TOTP) 기반의 키 유효성 검증을 통한 보안 강화

이 기능은 TOTP(Time-based One-Time Password) 시스템에서 영감을 받아, 암호화된 데이터의 유효 시간을 극히 제한함으로써 보안성을 획기적으로 향상시킵니다.

구현 개념

- 암호화 및 복호화의 핵심 요소인 IV(Initialization Vector)를 현재 시간에 동기화하여 생성합니다.
- 암호화 시 사용된 IV는 코드 1분 내에서만 유효하며, 이 시간이 지나면 해당 IV로는 데이터를 올바르게 복호화할 수 없게 됩니다.

동작 방식

- **암호화:** `get_time_synced_iv` 함수가 실행 시점의 타임스탬프(`time.time() // 60`)를 기반으로 IV를 생성합니다. 이 IV는 암호화된 데이터와 함께 파일에 저장됩니다.
- **복호화:** `PBE_Decryption` 함수는 전체 복호화 시도 시간을 50초로 제한합니다. 사용자가 50초 안에 올바른 패스워드를 입력하지 못하면 프로세스가 강제 종료됩니다. 설령 올바른 패스워드를 입력하더라도, 암호화가 진행된 시간 구간(1분)이 지나버리면 IV가 일치하지 않아 복호화에 실패하게 됩니다.

관련 코드

- `get_time_synced_iv` (16-22행): 암호화 시 시간 기반 IV를 생성합니다.
- `PBE_Decryption` (120-123, 135-143행): 복호화 시 60초의 시간제한을 두며, 시간 초과 시 프로세스를 종료하고 IV 불일치 시 예외 처리를 수행합니다.